

FINAL EXAM

NAME: Group:

Time to complete the final exam: **90 minute**. Minimum points to pass the final exam: **18p**. Good luck!

1. **Good usage of reverse engineering**

Which of the following represent proper/good/ethical usage of reverse engineering (e.g., in terms of ethical hacking)? Mark your selection with OK. Mark the rest with NOK. The first one is done as an example.

- (a) Bypass the authentication of a paid app. ... **NOK** ...
- (b) Check for code errors. **(2p)**
- (c) Modify the code to get access to functionalities you should normally not be entitled to. **(2p)**
- (d) Check for undocumented functionalities. **(2p)**
- (e) Check for behaviour in special cases, boundary conditions, etc. **(2p)**
- (f) Crack an app from its free version to its paid version **(2p)**
- (g) Search the code for possible malware. **(2p)**

2. **General concepts/notions**

Choose the correct concept/notion (cut the incorrect answers with a line) or fill in the blanks in the text below. The first one is done as an example.

Mathew is a reverse engineer. He is looking into ~~open-source~~/*non open-source* software to find its functionality and search for possible malware. In his job, he gets access to some *binary files/text files* **(2p)**, such as, e.g., *PE/TXT* **(2p)** files. He is currently examining an ELF file, identified as such by the file signature (or magic number) 7F 45 4C 46/50 45 00 00 **(2p)**. To perform his tasks, he is initially examining the code without running it, which means he is performing a *static analysis/dynamic analysis* **(2p)**. Mathew runs the **(2p)** command to display information about the file; he finds the start of the section header to be 0x4AAED0 and the size of the section headers to be 64 bytes. He further uses the option `-section-headers` of the same command and finds the index of section `.data` to be 23. Mathew computes that the `.data` section starts at **(2p)**. In the `.data` section he is identifying the sequence (0x) 36 32 37 34, which he immediately understands it must be a *number value/cmp instruction* **(2p)**. Mathew is further performing a more in-depth analysis and debugging. He is using `gdb-peda` and runs `vmmap/aslr` **(2p)** to find the virtual mapping address ranges ...

3. **Assembly**

Given the assembly code below, explain its functionality in 1-2 phrases. Explicitly mention the value of a "secret value" of interest and what it represents. **(8p)**

```
vrf_pin(int, int):
    push    rbp
    mov     rbp, rsp
    mov     DWORD PTR [rbp-4], edi
    mov     DWORD PTR [rbp-8], esi
    mov     eax, DWORD PTR [rbp-4]
    cmp     eax, DWORD PTR [rbp-8]
    sete    al
    movzx   eax, al
    pop     rbp
    ret

main:
    push    rbp
    mov     rbp, rsp
    sub     rsp, 32

    mov     DWORD PTR [rbp-4], 7253
    movabs  rax, 7598805555174203734
    movabs  rdx, 5282757987228741231
    mov     QWORD PTR [rbp-32], rax
    mov     QWORD PTR [rbp-24], rdx
    mov     WORD PTR [rbp-16], 78
    mov     edx, DWORD PTR [rbp-4]
    mov     eax, DWORD PTR [rbp-8]
    mov     esi, edx
    mov     edi, eax
    call    vrf_pin(int, int)
    mov     DWORD PTR [rbp-12], eax
    mov     eax, 0
    leave
    ret
```

Answer:

4. True/False

Respond with true (T) or false (F) and give a short explanation of your choice.

- (a) ASLR allows segment addresses to change while the process is running. **(2p)**

Answer:

- (b) GOT and PLT segments exist for both statically and dynamically linked ELF binaries. **(2p)**

Answer:

TOTAL available: 40p